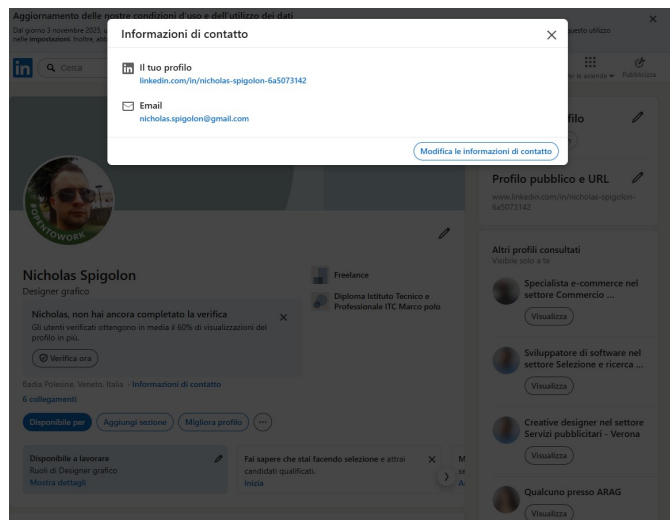


Report

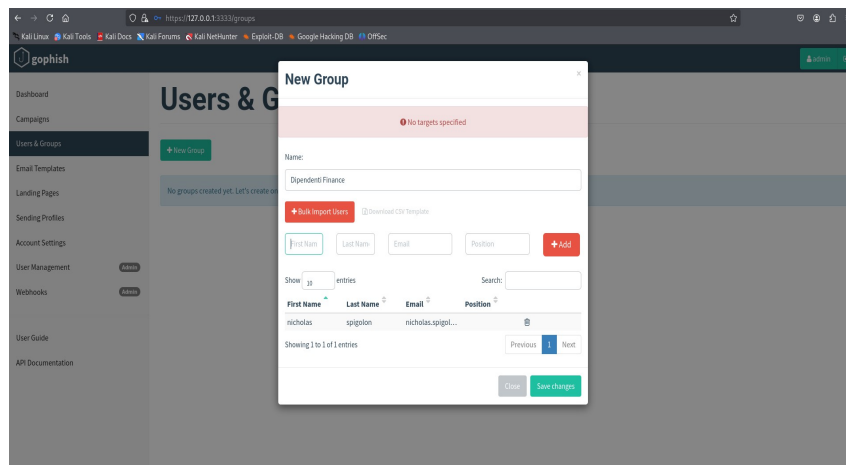
Spiego ad un datore del lavoro un possibile scenario di campagna phishing che può fare leva alle emozioni dei dipendenti e caderci nell'esca. Inizio raccogliendo informazioni in modalità passiva, tramite social network e Google digitiamo i nomi dei dipendenti e vediamo i risultati in modo da trovare più email possibili all'interno di quell'azienda. Passaggio successivo non c'è spavento più grande di trovarsi una bella email di una multa fingendomi per la Polizia locale, quindi uso il PagoPa rapida ed immediata perchè l'utente quando vede il codice QR è invogliato subito a pagarla, una volta che vi accederà ci fornirà già i suoi dati personali e bancari una volta che avrà tentato il pagamento. Lo strumento che useremo sarà Gophish. Prendo un sito target copio l'header dell'email di testo lo clono e la invio al mal capitato in modo da bypassare i protocolli di sicurezza. Illustrerò i seguenti passaggi dall'inizio alla fine.



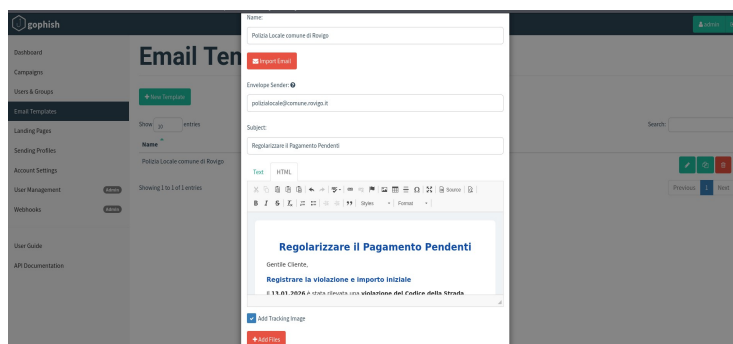
1- Trovo i nomi dei dipendenti e ne prendo i loro indirizzi email

```
Delivered-to: nicholas.spigolon@gmail.com
Received: by 2002:a05:6008:26cf:a04:1f45:457e with SMTP id i47-nlcsp23594bly; Thu, 23 Apr 2026 18:32:42 -0700 (PDT)
X-Forwarded-Encrypted: i=1; AFRE11gGt5G5JBL9k2R1D0WqY3w6wMqN114ldyBacVf3k400u8AEf4eC324771a1d0V2B4V1CQ=@gmail.com
X-Received: by 2002:a05:6008:26cf:a04:1f45:457e with SMTP id ffacdb85a97d4411a548d5e20093918f8f.13.17769552721; Thu, 23 Apr 2026 18:32:42 -0700 (PDT)
ARC-Source: i=1; arisa-sha256; t=177695562; c=relaxed/relaxed; d=studenti.unimol.it; s=google; t=177695562; h=ml-e-version:auto-submitted:message-id:subject:reply-to:from:to:date:domain:signature; bh=2u555qcdg4dw4B8uq06dp166912oc0C7vLB4+; fh=b-yJg21u005vlnpugw17K13M759hweh; GzLcY=; b=Nv4l3/AM/ARCY2uak/120Fb24F08Z22jgho481fe4l86g1T3o4/ytki; Cqcd74dHFEVqpmR41361411Tgy1ZV1og466Fp7yBa4vz0d8gR2d8k4H; Hc1rc4p413400s4h4l1mg0w4315u0p9cy45C711u4C22199F3M4V1E; H830u64n1B1B20u4s05d0e89y4/6P4M24m04/r4L1Q4uq1Y5G6H4hC3F; zH1Dy7Vtq4G1ghL8F2gThfHud4c1A08M400/L4G02C1/BG4317HmCov_F2k4+; darargoogle.com
ARC-Authentication-Results: i=1; mx.google.com; dkim=pass header.i=@studenti.unimol.it header.s=google header.b=1zck4f; spf=pass (google.com: domain of garofalo.195742@studenti.unimol.it designates 209.85.220.41 as permitted sender) smtp.mailfrom=garofalo.195742@studenti.unimol.it; dmarc=pass (p=REJECT sp=REJECT dls=NONE) header.from=studenti.unimol.it; dara=pass header.i=@gmail.com
Return-Path: <garofalo.195742@studenti.unimol.it>
Received: from mail-sor-f41.google.com (mail-sor-f41.google.com [209.85.220.41]) by mx.google.com with SMTPS id ffacdb85a97d-43fe4c4c3c9291109f8f.1.2026.04.23.18.32.42 for <nicholas.spigolon@gmail.com> (Google Transport Security); Thu, 23 Apr 2026 18:32:42 -0700 (PDT)
Received-SPF: pass (google.com: domain of garofalo.195742@studenti.unimol.it designates 209.85.220.41 as permitted sender) client-ip=209.85.220.41; Authentication-Results: mx.google.com; dkim=pass header.i=@studenti.unimol.it header.s=google header.b=1zck4f; spf=pass (google.com: domain of garofalo.195742@studenti.unimol.it designates 209.85.220.41 as permitted sender) smtp.mailfrom=garofalo.195742@studenti.unimol.it; dmarc=pass (p=REJECT sp=REJECT dls=NONE) header.from=studenti.unimol.it; dara=pass header.i=@gmail.com
DKIM-Signature: v=1; arisa-sha256; c=relaxed/relaxed; d=studenti.unimol.it; s=google; t=177695562; h=ml-e-version:auto-submitted:message-id:subject:reply-to:from:to:date:domain:signature; bh=2u555qcdg4dw4B8uq06dp166912oc0C7vLB4+; fh=b-yJg21u005vlnpugw17K13M759hweh; GzLcY=; b=Nv4l3/AM/ARCY2uak/120Fb24F08Z22jgho481fe4l86g1T3o4/ytki; Cqcd74dHFEVqpmR41361411Tgy1ZV1og466Fp7yBa4vz0d8gR2d8k4H; Hc1rc4p413400s4h4l1mg0w4315u0p9cy45C711u4C22199F3M4V1E; H830u64n1B1B20u4s05d0e89y4/6P4M24m04/r4L1Q4uq1Y5G6H4hC3F; zH1Dy7Vtq4G1ghL8F2gThfHud4c1A08M400/L4G02C1/BG4317HmCov_F2k4+; darargoogle.com
X-Forwarded-Encrypted: i=1; AFRE11gGt5G5JBL9k2R1D0WqY3w6wMqN114ldyBacVf3k400u8AEf4eC324771a1d0V2B4V1CQ=@gmail.com
X-Received: by 2002:a05:6008:26cf:a04:1f45:457e with SMTP id ffacdb85a97d-43fe4c4c3c9291109f8f.1.2026.04.23.18.32.42 for <nicholas.spigolon@gmail.com> (Google Transport Security); Thu, 23 Apr 2026 18:32:42 -0700 (PDT)
Return-Path: <garofalo.195742@studenti.unimol.it>
Received: from localhost ([192.74.150.46]) by smtp.gmail.com with ESMTPS id ffacdb85a97d-43fe4c4c3c9291109f8f.1.2026.04.23.18.32.38 (version=TLS1_3 cipher=TLS_AES_256_GCM_SHA384 bits=256/256); Thu, 23 Apr 2026 18:32:41 -0700 (PDT)
Date: Thu, 23 Apr 2026 19:32:37 +0200
```

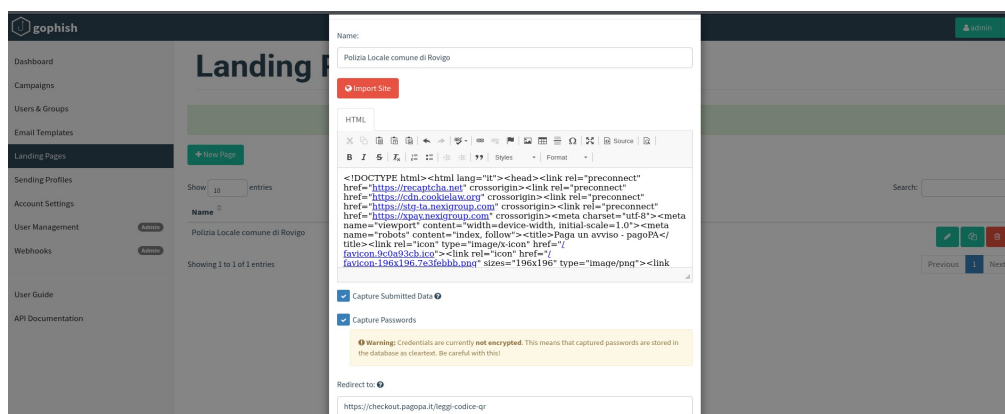
2- Prendo L'Header di una e-mail esistente



3- Faccio un gruppo di Utenti



4- Clono l'e-mail malevolo



5- Imposto un link in modo che il dipendente una volta cliccato sopra lo manderà in un'altra pagina se ingenuo dal folgore effettuerà il pagamento.

Per capire se quell'email è malevolo si analizza l'email del mittente vedendo il suo sorgente originale se compare PASS nelle voci SPF - DKIM - DMARC vuol dire che l'email è riuscito a superare i controlli di sicurezza. E se succederà il datore di lavoro è dovuto far fare un mini corso sulla prevenzione agli attacchi informatici ai propri dipendenti.

